

Halden Distribution Ltd. — executive brief: risk-based vulnerability remediation

To: Managing Director, Finance Director, Operations Director **From:** IT (Muhammad Ibrahim Akmal) · **Date:** 2026-10-02 · **Read time:** 2 minutes **Follows:** the cyber-insurance scan that returned 400 "critical" findings

The problem in one paragraph

We patch when someone has time, and a recent scan produced 400 "critical" findings. We cannot fix 400 things, and neither can a company ten times our size. The real question is not "how many findings do we have?" — it is "which of them would an attacker actually use against Halden, and which would actually hurt us?" Those are very different lists, and treating them as the same list is why small IT teams either burn out or leave the important things undone.

Why "fix everything by Friday" is not a plan

If we try to fix everything at once	What actually happens
Weeks of overtime, every change rushed	A rushed patch takes out a service the business needs — the classic "we patched payroll" failure
No ring testing	One bad update reaches all 85 people at once, and nobody knows until the phones ring
No priority	The firewall firmware sits unfixed while we argue about a low-risk setting on a spare laptop
Nothing verified	Tickets get closed because someone ran an update, not because the risk is gone
No record	When the next scan shows the same findings, we cannot tell what was fixed or why anything was accepted

What we agreed to do instead: fix the few that matter, schedule the rest

IT has written a **risk-based remediation standard**. In plain terms:

1. **Every finding gets a tier** based on four things: whether it is *already being exploited* in the wild, how likely exploitation is, whether the system is *reachable from outside*, and how much the business depends on it.
 1. **The top two tiers are the only ones that interrupt other work.** Everything else goes into a scheduled cycle or is formally accepted.
 1. **Targets, not slogans.** The highest tier is fixed within 3 days; everything else has a stated, achievable window.
 1. **Nothing is "fixed" until a re-scan says so.** That is how we can tell you the truth about where

we stand.

1. **Anything we choose not to fix is signed off by a named owner**, with a control in place and an expiry date — not quietly forgotten.

What we need from the business

Ask	From whom	Why
Approve the remediation standard (tiers and targets)	Management	It is a business decision about risk appetite, not a technical one
Approve downtime windows for server patching	Department heads	Servers patch in a Saturday window; the business approves the outage
Nominate an owner for each critical business system	Each department	Someone must decide when "fix now" outweighs "keep it running"
Budget or replacement decision for the firewall	Management / Finance	Vendor updates only fix supported hardware; an ageing device needs a plan, not another patch

What this gives us

- **A short list instead of a wall of red.** IT works from a ranked queue, and the ranking is explainable in one sentence per item.
- **Honest reporting.** Every month you get open-by-tier, what is overdue, and what we are asking of you — with the source of each figure.
- **An audit trail.** Every change has a record; every accepted risk has a signature and an expiry.

Note on the numbers in this brief: this document is a home-lab artefact for a fictional company (Halden Distribution Ltd.). The methodology is real and is built in the lab; no remediation percentage, SLA achievement or cost figure is quoted here because none has been measured yet. When those numbers exist, they will come from real runs, with a source file for each.